

Post-Quantum Cryptography and Enterprise Security Migration

Sotheavatey Thao

Master's Concentration: Computer Science

Avila University

CS 694 20 Computer Science Capstone PtA 2026 SU

Instructor: Shawn C. Smith

August 22, 2026

Abstract

Organizations depend on RSA, Diffie-Hellman, and elliptic curve cryptography for authentication, secure communications, digital signatures, and protection of sensitive information, yet sufficiently capable quantum computers could make these public key mechanisms vulnerable. This white paper examines how enterprises can migrate to post-quantum cryptography (PQC) while maintaining security, performance, interoperability, and business continuity. The final evidence base integrates scholarly literature, NIST and industry guidance, and a case study of IBM Db2. The analysis finds that successful migration requires cryptographic discovery and dependency mapping, risk based prioritization, standardized algorithms, crypto agility, cross functional governance, vendor coordination, and representative testing. The Db2 case demonstrates that legacy code, incomplete documentation, hard coded assumptions, and compatibility requirements may create more implementation difficulty than the cryptographic algorithms themselves, while its tested post-quantum key establishment change did not produce a meaningful performance penalty. The paper recommends a comprehensive cryptographic inventory, a phased migration roadmap, crypto agile architecture, workforce preparation, vendor accountability, and continuous security, performance, and interoperability testing. These actions position technology managers to reduce long term quantum risk while strengthening operational resilience, modernization readiness, and future cryptographic adaptability.

Executive Summary

Problem and Opportunity

Enterprises rely on public key cryptography throughout applications, databases, certificates, cloud services, identity platforms, software updates, and vendor products. Much of this infrastructure depends on RSA, Diffie-Hellman, or elliptic curve cryptography, all of which could become vulnerable to a sufficiently capable quantum computer. The opportunity is to prepare before the threat becomes an operational emergency. Because cryptographic transitions across complex organizations can take years, early preparation allows leaders to spread cost and technical effort over time, reduce disruption, and combine quantum readiness with broader software and security modernization.

Why the Issue Matters

The challenge is larger than choosing a new encryption algorithm. Cryptography is frequently embedded in source code, libraries, protocols, certificates, databases, hardware, firmware, cloud services, and third party products. A change in one component can affect dependent applications, customers, partners, and vendors. Long lived sensitive information also creates a present concern because data collected today may still require confidentiality when stronger quantum capabilities exist. Delaying preparation can therefore increase future cost and exposure, while a rushed migration can introduce outages, authentication failures, interoperability problems, insecure fallback configurations, and compliance risk.

Purpose and Evidence Base

The purpose of this white paper is to examine how enterprises can implement a secure, structured, and sustainable transition to PQC while maintaining security, performance, interoperability, and business continuity. The final analysis combines scholarly research and

standards guidance with a case study of IBM Db2. The literature addresses quantum risk, cryptographic inventories, dependency analysis, NIST standardized algorithms, crypto agility, governance, vendor readiness, performance testing, implementation security, and phased migration. The Db2 case provides a practical view of how these issues appear inside mature enterprise software with extensive legacy code, incomplete documentation, compatibility requirements, and multiple technical stakeholders.

Major Findings

Four findings are especially important. First, migration must begin with discovery because organizations cannot prioritize cryptographic risks they cannot see. A current inventory and dependency map are necessary to identify algorithms, keys, certificates, protected data, system owners, vendors, retention periods, and affected services. Second, PQC migration is a technology management and modernization program rather than an isolated security engineering task. Leadership, cybersecurity, development, architecture, database administration, risk, compliance, procurement, audit, and vendors all influence migration sequence and success. Third, despite the reduction of uncertainty by standardized algorithms, deployment still requires security, performance, interoperability, regression and rollback testing in representative environments. The IBM Db2 case found that a Kyber based key establishment change did not create a meaningful performance penalty in its tested connection workload, but the project encountered legacy assumptions, documentation gaps, changing interfaces, and underestimated implementation effort. Fourth, crypto agility is a lasting organizational capability. Systems designed with modular cryptographic libraries, configurable policies, flexible certificate and key handling, and documented interfaces are better prepared for PQC and for future cryptographic changes.

Practical Recommendations

The paper recommends five coordinated actions. Organizations should develop and maintain a comprehensive cryptographic inventory; create a risk based phased migration roadmap that prioritizes long lived sensitive data and mission critical systems; adopt NIST standardized mechanisms while designing for crypto agility; establish cross functional governance, workforce preparation, and vendor accountability; and require continuous testing, documentation, monitoring, and rollback planning. Organizations should use controlled pilots before deploying widely in production to establish baselines, measure operational impact, fix compatibility issues and ensure that security improvements don't come at the cost of service continuity.

Anticipated Benefits and Implications

A structured migration program can reduce exposure to future quantum attacks while limiting disruption to current operations. It can also provide immediate benefits by improving visibility into existing cryptographic risk, strengthening architecture and vendor governance, reducing technical debt, clarifying ownership, and creating reusable processes for future security transitions. For technology managers, the central implication is that quantum readiness should be measured by organizational capability rather than by whether every system has already been converted. Enterprises that know where cryptography is used, understand dependencies, assign ownership, test changes systematically, and can replace cryptographic components in controlled phases will be better positioned to protect long lived information and preserve business continuity as post-quantum adoption expands.

Introduction

Modern organizations use public-key cryptography to authenticate users, establish secure connections, verify digital signatures, and protect sensitive information. RSA, Diffie-Hellman, and elliptic-curve cryptography are embedded in applications, databases, certificates, cloud services, protocols, and vendor products. Shor's (1994) algorithm demonstrated that a sufficiently powerful quantum computer could solve the mathematical problems supporting many of these methods. Although the exact timeline for cryptographically relevant quantum computing is uncertain, the long duration of enterprise cryptographic transitions makes preparation a current technology management concern.

In 2024, the National Institute of Standards and Technology standardized ML-KEM, ML-DSA, and SLH-DSA, providing technical targets for post-quantum key establishment and digital signatures (National Institute of Standards and Technology [NIST], 2024a, 2024b, 2024c). Standardization, however, does not remove implementation complexity. Cryptography may be hidden in source code, libraries, certificates, hardware, firmware, protocols, and third party services. Campbell (2026) similarly describes enterprise migration as a multi year effort affected by technical debt, vendor readiness, staffing, and organizational complexity.

The purpose of this white paper is therefore to examine how enterprises can migrate from quantum vulnerable public key cryptography to PQC while maintaining security, performance, interoperability, and business continuity. A supporting question considers what the IBM Db2 case reveals about technical and organizational migration challenges. The literature review and case study provide complementary evidence: the literature explains recurring migration requirements, while the Db2 case demonstrates how those requirements appear in mature

enterprise software (Barker et al., 2021; Hasan et al., 2024; Näther et al., 2024; Zhang et al., 2023).

Literature Review Synthesis

Quantum Risk and Migration Urgency

The literature establishes the technical basis for migration through Shor's (1994) demonstration that a sufficiently capable quantum computer could efficiently solve integer factorization and discrete logarithm problems. These problems support widely used public key mechanisms. Liu and Moody (2024) emphasize that the risk can begin before a practical quantum attack exists because adversaries may collect encrypted data now and attempt to decrypt it later. This harvest now, decrypted later concern is especially relevant for information that must remain confidential for many years.

Uncertainty about the arrival date of cryptographically relevant quantum computers does not eliminate the need for planning. Barker et al. (2021) Cryptographic transitions require coordination across protocols, applications, devices, certificates, and vendor products. ETSI (2020) also characterizes migration as a process of transition and not as a direct conversion. Campbell (2026) goes on to explain that the realistic migration timeline is dependent upon the size of the enterprise, legacy dependencies, personnel, quality of planning, and coordination of the supply chain. These are particularly useful for organizations with long lived data or systems that are hard to replace. They encourage getting ahead of the curve.

Standards, Implementation, and Crypto-Agility

NIST's 2024 standards reduce algorithm selection uncertainty. ML-KEM provides a standardized key encapsulation mechanism, while ML-DSA and SLH-DSA provide digital signature standards (NIST, 2024a, 2024b, 2024c). Even so, algorithm and parameter choices

must be evaluated against bandwidth, latency, certificate size, device limits, implementation maturity, and interoperability. Kumar (2022) shows that post-quantum algorithm families differ substantially in key and signature sizes and computational requirements. Secure deployment also requires more than mathematical resistance. Shaller et al. (2023) note that timing, power analysis, fault, and other implementation attacks remain relevant.

Crypto agility therefore emerges as a core migration principle. Barker et al. (2021) define crypto agility as the ability to replace cryptography algorithms without the need to completely redesign the system. According to Näther et al. (2024), substantial implementation challenges, system complexity, security concerns, and a lack of practical expertise remain persistent barriers to migration. Marchesi et al. (2025) found that practitioners and researchers found software engineering methodologies (e.g., continuous integration and coding standards) useful to enable crypto agility in the migration to quantum resistant cryptography. All these results together support modular libraries, policies that can be adapted, centralized certificate management, good documentation and reproducible testing methods.

Enterprise Readiness and Phased Implementation

Migration begins with visibility. Hasan et al. (2024) propose cryptographic inventories and security dependency analysis to identify assets, map system relationships, and prioritize replacements. This is important because cryptography may be embedded in applications, libraries, firmware, protocols, and managed services. A simple list of algorithm names is not enough to determine migration order; leaders also need to know what data is protected, how long it must remain confidential, who owns the system, which vendors are involved, and what other services depend on it.

The literature generally supports phased implementation and representative testing. In 2023, the National Security Agency, NIST and Cybersecurity and Infrastructure Security Agency prioritize inventories, supply chain coordination, roadmaps and organizational readiness. Sikeridis et al. (2020) show that the post-quantum overhead in TLS 1.3 and SSH is dependent on the network conditions, protocol and algorithm. Hybrid approaches may reduce the transition risk but also increase the protocol's complexity and testing requirements (ETSI, 2020; Näther et al., 2024). The strongest synthesis is therefore a controlled process that combines discovery, risk prioritization, standardized algorithms, crypto agile design, vendor coordination, and measured pilot deployment.

Synthesis and Research Gaps

Across the literature, the most consistent conclusion is that successful PQC migration requires coordinated technical and organizational change. Important gaps remain because many implementation reports involve pilots, prototypes, or individual products rather than completed enterprise wide migrations. Comparative data on cost, staffing, vendor readiness, regulated industry constraints, hybrid operation duration, and long term production performance remain limited (Hasan et al., 2024; Näther et al., 2024). These boundaries make case study evidence useful while also requiring careful limits on generalization.

Case Study Analysis

IBM Db2 Background and Migration Approach

IBM Db2 was selected because it is a mature enterprise database platform in which authentication and encrypted client server communication depend on cryptographic components. In the case study, parts of the design relied on Diffie-Hellman for key establishment, RSA for authentication related signatures, and TLS for protected communication. The research team

adopted a structured 7E roadmap that included leadership engagement, evaluation of existing security components, transition to crypto agility, stakeholder education, impact estimation, execution, and post change assessment (Zhang et al., 2023).

The project involved IBM security leadership, Db2 developers, security architects, cryptographic library specialists, and university researchers. The team used IBM's Global Security Kit libraries, replaced the vulnerable Diffie-Hellman key establishment process used in the tested authentication path with Kyber, upgraded transport security from TLS 1.2 to TLS 1.3, and worked with Dilithium based signatures. Kyber and Dilithium later became the foundations for NIST's ML-KEM and ML-DSA standards (NIST, 2024a, 2024b; Zhang et al., 2023).

Outcomes and Practical Lessons

The team compared 1,000 database connections using the Kyber based process with 1,000 using Diffie-Hellman. Average connection time was 162.514 milliseconds for Kyber and 163.552 milliseconds for Diffie-Hellman, indicating no meaningful performance penalty in that controlled workload (Zhang et al., 2023). The result is important as a feasibility finding, but it should not be generalized to every application, platform, or network.

Table 1

IBM Db2 Connection Time Comparison

Method	Average time	Interpretation
Kyber-based	162.514 ms	No meaningful penalty in the tested workload
Diffie-Hellman	163.552 ms	Classical comparison method

Note. Data are from Zhang et al. (2023). The finding demonstrates feasibility in one controlled test environment, not universal performance superiority.

The key lessons from the more significant case study lessons were the implementation difficulty. The team faced a variety of issues such as incomplete or out of date documentation, legacy development limitations, long build times, hard coded and inconsistent key size checks, the need for compatibility with older clients, evolving cryptographic interfaces and effort that was underestimated. These challenges suggest that the cost of migration may be as much a function of technical debt and organizational knowledge as the algorithms themselves. The case further emphasizes the value of management support, cross functional collaboration, early education, schedule buffers, systematic removal of hard coding, documentation, and performance measurement (Zhang et al., 2023).

This is consistent with the Db2 experience in the literature. Barker et al. (2021) focus on governance and crypto agility, and Hasan et al. (2024) focus on inventories and dependency mapping. In Db2, cryptographic assumptions appeared beyond the primary authentication component, illustrating why dependency analysis must extend across code and interfaces. The case therefore provides practical evidence that a structured migration roadmap can work, while also showing why enterprise wide conversion should be planned as a phased modernization effort rather than a one time security patch.

Discussion and Recommendations

The literature and case study lead to a consistent conclusion: PQC migration is an enterprise risk management and software modernization program. The most important recurring themes are early planning, cryptographic discovery, dependency analysis, standardized algorithms, vendor coordination, crypto agility, and phased testing (Cybersecurity and Infrastructure Security Agency et al., 2023; Hasan et al., 2024; Näther et al., 2024). The Db2 case brings practical significance to these themes by showing how legacy code, documentation

gaps, hard coded assumptions and compatibility requirements can significantly increase migration effort (Zhang et al., 2023).

From a technology management perspective, cryptography needs to be managed as an enterprise asset. Security teams need to be up to date with information about algorithms, certificates, keys, protected data, owners, confidentiality periods, vendors and dependencies. Leaders can rank systems by their regulatory importance, difficulty of replacement, exposure, criticality, and sensitivity. This approach mitigates the risk of an unrealistic organization wide conversion and helps to preserve business continuity.

Table 2

Enterprise Post-Quantum Migration Roadmap

Phase	Primary action	Readiness evidence
Discover	Inventory cryptography, data, owners, vendors, and dependencies	Current inventory and dependency map
Prioritize	Rank systems by sensitivity, lifespan, criticality, and replacement difficulty	Approved risk based sequence
Pilot	Test standardized mechanisms in representative environments	Security, performance, interoperability, and rollback results
Scale	Migrate in controlled waves with change control and vendor coordination	Stable production metrics

Phase	Primary action	Readiness evidence
Sustain	Monitor, document, train, and preserve crypto agility	Updated lifecycle controls and ownership

Note. Barker et al., 2021; Campbell, 2026; ETSI, 2020; Hasan et al., 2024; Näther et al., 2024; Zhang et al., 2023)

Recommendations

1. Make a list of all your cryptocurrency investments

Describe the use of public key cryptography in libraries, devices, applications, protocols, certificates and vendor products. Document key length, algorithm, information protected, owners, retention periods, and dependencies to support migration preferences based on empirical evidence (Cybersecurity and Infrastructure Security Agency et al., 2023; Hasan et al., 2024).

2. Create a phased roadmap based on risk

Data sensitivity, duration of confidentiality, criticality of operations, importance of regulations, exposure and replacement difficulty based on ranking systems. Test the changes before deploying for clients or for critical systems. For each phase, specify success metrics, contingency plans, and accountable entities (Campbell, 2026; ETSI, 2020; Zhang et al., 2023).

3. Create Crypto Agility and Use Standard Algorithms

Don't hard wire any specific algorithm or key length into your architecture. Instead, choose designs that incorporate NIST standardized mechanisms such as ML-KEM, ML-DSA and SLH-DSA. The use of modular libraries, centralized certificate administration, configurable policies, and structured development methodologies contributes to reduce future migration costs (Barker et al., 2021; Marchesi et al., 2025; NIST, 2024a, 2024b, 2024c).

4. Improve governance, training and vendor accountability

Use a cross functional steering group with cybersecurity, software development, architecture, database administration, risk, compliance, procurement, audit and leadership. Require vendors to provide cryptographic dependencies, migration schedule and compatibility effects. Provide role based PQC training.

5. Continuous Testing and Documentation Required

Establish performance baselines and test functionality, regression, interoperability, security, load and rollback prior to deployment into production. Continue to monitor and document the cryptographic architecture post release: exceptions, decisions, dependencies, lessons learned, etc. Future teams shouldn't have to reconstruct it.

Ethical Considerations and Implementation

Implementation can be complex with larger keys or signatures, limited expertise, legacy systems, vendor delays and competing modernization priorities. Hybrid approaches can help to ease transitions, but can also increase the risk of configuration and protocol complexity. Organizations should not deploy unvalidated implementations just to keep up the pace as this can be detrimental for the organizations' reputation and the reputation of the implementation. Responsible migration should have clear options for rollback, transparent prioritization, documented acceptance of risk, and communication with affected stakeholders. These controls help to balance the urgent need to keep operations stable, accessible, and available with the long term need to protect sensitive information.

The aim of this white paper was to explore how enterprises can migrate from quantum vulnerable public key cryptography to PQC while also maintaining security, performance, interoperability, and business continuity. As the combined literature and IBM Db2 case study illustrates, migration is not a straightforward algorithm replacement. It is a multi year enterprise

modernization effort that depends on cryptographic visibility, risk prioritization, architecture, governance, testing, vendor coordination and disciplined implementation.

The main takeaway is that organizations need to begin with a discovery. The dependency map and cryptographic inventory allow leaders to see sensitive data, systems impacted, responsible owners, third party dependencies, and areas that will be hard to migrate due to legacy design. The evidence also indicates the need to treat crypto agility as a permanent capability. Modular libraries, configurable policies, dynamic key handling, documented interfaces, and repeatable development practices are more likely to take up new standards and deal with future vulnerabilities (Marchesi et al., 2025; Barker et al., 2021).

The Db2 case is an example of how post-quantum mechanisms can be feasible in enterprise software without necessarily leading to unacceptable performance. More importantly, it illustrates that legacy code, incomplete documentation, hard coded assumptions, and compatibility requirements can produce a substantial amount of work (Zhang et al. 2023). This directly involves technology managers who need to coordinate security, development, architecture, database administration, risk, compliance, procurement, leadership and vendors. Therefore, it is most appropriate to think of quantum readiness as an enterprise risk management obligation.

The practical implications are not confined to the immediate quantum threat. Cryptographic inventories, modularization of security components, better management of certificates and keys, increased vendor requirements and documentation of system dependencies can improve the current state of cybersecurity operations. These processes will enable future crypto transitions, modernization planning, compliance, and incident response. The research suggests that PQC shouldn't be treated as a specialized project owned only by cryptographers,

but rather integrated into larger architecture and risk management programs by technology managers. This is particularly important because enterprise migrations can take years to complete and early preparation can spread costs over time and minimize emergency changes (Campbell, 2026).

Future research should focus on the cost of implementation, staffing, vendor coordination, regulatory requirements, long term hybrid operation and operational performance of full scale production migrations in multiple industries. Additional work is needed on automated cryptographic discovery, cloud service dependencies, certificate lifecycle management, measurable crypto agility, and governance outcomes. As standardized PQC becomes more widely deployed, longitudinal case studies will help determine which migration models provide the best balance of security, resilience, cost, and interoperability.

Overall, organizations should not wait for quantum computing to become an immediate operational emergency before preparing. A phased program that begins with discovery, uses recognized standards, tests changes in representative environments, coordinates with vendors, and builds crypto agility can reduce future risk while producing near term benefits in documentation, architecture quality, and security governance. The exact timing of a cryptographically relevant quantum computer remains uncertain, but the complexity and duration of enterprise migration make proactive preparation a practical and evidence based strategy.

References

- Barker, W., Polk, W., & Souppaya, M. (2021). Getting ready for post-quantum cryptography: Exploring challenges associated with adopting and using post-quantum cryptographic algorithms (NIST Cybersecurity White Paper 15). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.15>
- Campbell, R. (2026). Enterprise migration to post-quantum cryptography: Timeline analysis and strategic frameworks. *Computers*, 15(1), Article 9. <https://doi.org/10.3390/computers15010009>
- Cybersecurity and Infrastructure Security Agency, National Security Agency, & National Institute of Standards and Technology. (2023, August). Quantum-readiness: Migration to post-quantum cryptography. <https://www.cisa.gov/resources-tools/resources/quantum-readiness-migration-post-quantum-cryptography>
- European Telecommunications Standards Institute. (2020). Cyber; Migration strategies and recommendations to quantum safe schemes (ETSI TR 103 619 V1.1.1). https://www.etsi.org/deliver/etsi_tr/103600_103699/103619/01.01.01_60/tr_103619v010101p.pdf
- Hasan, K. F., Simpson, L., Baee, M. A. R., Islam, C., Rahman, Z., Armstrong, W., Gauravaram, P., & McKague, M. (2024). A framework for migrating to post-quantum cryptography: Security dependency analysis and case studies. *IEEE Access*, 12, 23427–23450. <https://doi.org/10.1109/ACCESS.2024.3360412>
- Kumar, M. (2022). Post-quantum cryptography algorithm's standardization and performance analysis. *Array*, 15, Article 100242. <https://doi.org/10.1016/j.array.2022.100242>

- Liu, Y.-K., & Moody, D. (2024). Post-quantum cryptography and the quantum future of cybersecurity. *Physical Review Applied*, 21(4), Article 040501.
<https://doi.org/10.1103/PhysRevApplied.21.040501>
- Marchesi, L., Marchesi, M., & Tonelli, R. (2025). A survey on cryptoagility and agile practices in the light of quantum resistance. *Information and Software Technology*, 178, Article 107604. <https://doi.org/10.1016/j.infsof.2024.107604>
- Näther, C., Herzinger, D., Gazdag, S.-L., Steghöfer, J.-P., Daum, S., & Loebenberger, D. (2024). Migrating software systems toward post-quantum cryptography—A systematic literature review. *IEEE Access*, 12, 132107–132126.
<https://doi.org/10.1109/ACCESS.2024.3450306>
- National Institute of Standards and Technology. (2024a). Module-lattice-based digital signature standard (FIPS 204). <https://doi.org/10.6028/NIST.FIPS.204>
- National Institute of Standards and Technology. (2024b). Module-lattice-based key-encapsulation mechanism standard (FIPS 203).
<https://doi.org/10.6028/NIST.FIPS.203>
- National Institute of Standards and Technology. (2024c). Stateless hash-based digital signature standard (FIPS 205). <https://doi.org/10.6028/NIST.FIPS.205>
- Shaller, A., Zamir, L., & Nojournian, M. (2023). Roadmap of post-quantum cryptography standardization: Side-channel attacks and countermeasures. *Information and Computation*, 295, Article 105112. <https://doi.org/10.1016/j.ic.2023.105112>
- Shor, P. W. (1994). Algorithms for quantum computation: Discrete logarithms and factoring. In *Proceedings of the 35th Annual Symposium on Foundations of Computer Science* (pp. 124–134). IEEE. <https://doi.org/10.1109/SFCS.1994.365700>

- Sikeridis, D., Kampanakis, P., & Devetsikiotis, M. (2020). Assessing the overhead of post-quantum cryptography in TLS 1.3 and SSH. In Proceedings of the 16th International Conference on Emerging Networking Experiments and Technologies (pp. 149–156). Association for Computing Machinery. <https://doi.org/10.1145/3386367.3431305>
- Zhang, L., Miranskyy, A. V., Rjaibi, W., Stager, G., Gray, M., & Peck, J. (2023). Making existing software quantum safe: A case study on IBM Db2. *Information and Software Technology*, 161, Article 107249. <https://doi.org/10.1016/j.infsof.2023.107249>